PHASE 3 — PRODUCTION

EPIPAY — ARCHITECTURE CIBLE

INFRASTRUCTURE CERTIFIÉE PCI-DSS L1 · SOC 2 · DSP2 · RGPD

SERVICE INTERNE · STOCKAGE / DONNÉES · SERVICE EXTERNE · SÉCURITÉ / EDGE

CLIENT

01 · FRONTEND

- **UTILISATEUR** — Étudiant Epitech
- **REACT NATIVE / PWA** — Expo · iOS / Android / Web

HTTPS / TLS 1.3

EDGE / SÉCURITÉ

02 · PERIMETER

- **CLOUDFLARE** (WAF) — DDoS Protection
- **AWS API GATEWAY** — Rate Limiting · Throttle
- **AWS COGNITO** (MFA) — Auth · JWT · SCA DSP2

TOKEN VALIDÉ

BACKEND PRODUCTION — MICROSERVICES

03 · CORE

- **API GATEWAY FASTAPI** — AWS Lambda / ECS
- **SERVICE WALLET** — Solde · Top-up · Transferts
- **SERVICE TRANSACTIONS** — Ledger · Historique
- **SERVICE FRAUD ML** — Scoring temps réel · Anomalies
- **SERVICE INTERCAMPUS** — Fédération campus partenaires
- **SERVICE KYC** — Vérification identité
- **SERVICE AML** — Screening sanctions
- **SERVICE NOTIFICATIONS** — Push · Email · SMS

DONNÉES

04 · PERSISTENCE

- **POSTGRESQL RDS** (Multi-AZ) — ACID · Réplication · Backup 7 ans
- **REDIS ELASTICACHE** — Cache · Rate limit · Sessions
- **AWS S3** — Documents KYC · Chiffré AES-256
- **SECRETS MANAGER** — Clés API · Rotation auto

PAIEMENTS / BANCAIRE

05 · MONEY

- **STRIPE** (PCI-DSS) — Cartes · 3DS · Webhooks
- **BRIDGE / TRUELAYER** — Agrégateur bancaire DSP2

CONFORMITÉ — KYC / AML

06 · REGULATION

- **ONFIDO / JUMIO** — KYC · Vérification ID
- **COMPLYADVANTAGE** — AML · Sanctions OFAC/EU
- **TRACFIN** — Déclarations soupçon

OBSERVABILITÉ

07 · MONITORING

- **DATADOG** — APM · Traces
- **SENTRY** — Exceptions
- **CLOUDWATCH** — Logs centralisés
- **PAGERDUTY** — Alerting 24/7

CHOIX CLOUD VS ON-PREMISE — JUSTIFIÉ

08 · DÉCISION INFRASTRUCTURE

CLOUD SOUVERAIN UE — CHOISI

AWS PARIS (EU-WEST-3) + SUPABASE FRANKFURT

- RGPD : données hébergées en UE, sous juridiction européenne (conforme hébergement données bancaires art. L.312-1 CMF).
- Certifications héritées : PCI-DSS L1, SOC 2 Type II, ISO 27001 (évite un audit full-stack interne).
- Scalabilité élastique : pics rentrée Sept (×3 volume) absorbés sans surprovisionnement.
- OPEX < CAPEX : pas d'investissement matériel initial, pay-as-you-go aligné sur la croissance users.
- Haute dispo native : multi-AZ, RTO < 5 min, SLA 99,99 % cible atteignable.
- Équipe réduite (5–7 pers.) : pas de sysadmin dédié, IaC via Terraform + managed services.

ON-PREMISE / COLOCATION — ÉCARTÉ

DATACENTER PROPRE OU BAIE LOUÉE OVH/SCALEWAY BARE-METAL

- CAPEX initial 80–150 k€ (serveurs, HSM, firewall, licences) — incompatible budget MVP.
- Certifications PCI-DSS / SOC 2 à obtenir en propre : +6–12 mois, +50–100 k€/an audit.
- Recrutement DevOps / SecOps dédié (2 ETP minimum) pour maintenance 24/7.
- Élasticité limitée : dimensionnement pic = surcoût matériel permanent.
- Plan de reprise d'activité (PRA) à concevoir, tester, maintenir en interne.
- Pertinent uniquement si > 500 k users OU exigence souveraineté stricte (OIV, défense).

VERDICT — CLOUD MANAGÉ UE RETENU POUR PHASE 3. HYBRIDATION ENVISAGÉE PHASE 4 (> 100 K USERS) : HSM DÉDIÉ ON-PREMISE POUR CLÉS CRYPTOGRAPHIQUES + CLOUD POUR LE RESTE. PAS DE VENDOR LOCK-IN DUR : IAC TERRAFORM PORTABLE, BASE POSTGRESQL STANDARD.